ENGINEERING & PRODUCT REPORT

● Live Deployment: https://phishsentry.onrender.com/

# PhishShift

Intelligent Phishing Detection, Evidence Verification, and Automated Threat Protection Platform

| PRODUCTION URL | CORE ARCHITECTURE | DETECTION ENGINES | DESIGN DIRECTION |
|---|---|---|---|
| https://phishsentry.onrender.com/ | React + Vite / Flask ML / Tesseract OCR | Logistic Regression + Link Heuristics | Hubtown Editorial / WCAG AA Compliant |

## 1. Executive Abstract

Social engineering and targeted phishing campaigns continue to cause devastating identity theft and monetary fraud. Conventional security scanners present end-users with dense telemetry, confusing technical jargon, and opaque numerical risk indices that fail to translate into safe user decisions.

**PhishShift** resolves this critical usability and security disconnect. Deployed live at `https://phishsentry.onrender.com/`, PhishShift delivers a consumer-grade security intelligence platform designed around three pillars:

- **Dual Ingestion Architecture:** Accommodates raw message text or image screenshots of suspicious SMS/emails via client-side, on-device OCR (Optical Character Recognition) with zero external image leakage.
- **Calibrated Detection Pipeline:** Evaluates lexical threat patterns via natural language processing (TF-IDF vectorizer + Logistic Regression) alongside zero-DNS heuristic inspection of deceptive lookalike domains and atypical top-level domains.
- **Human-First Evidence Explorer:** Replaces static dashboards with an interactive three-tool evidence suite structured in strict cognitive priority: *1. Message Heatmap* (default) → *2. Threat Map* → *3. Risk Categories*.

## 2. System Architecture & Processing Pipeline

The platform operates as a secure, distributed web system with decoupled presentation and inference tiers. The diagram below details the end-to-end dataflow from initial user input through on-device preprocessing, machine learning scoring, and interactive visual evidence delivery:

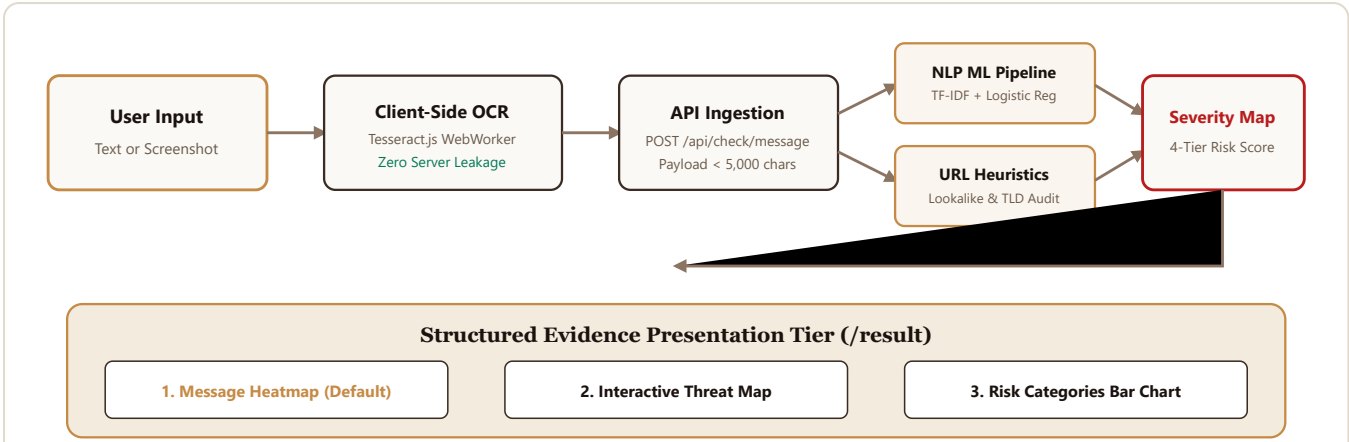



Figure 1: Full-Stack Ingestion, Machine Learning Classification, and Evidence Presentation Architecture

# 3. Key Modules & Technical Implementations

## 3.1 Client-Side On-Device OCR Scanner

To protect user confidentiality during SMS and mobile messaging audits, PhishShift implements local image processing using `tesseract.js`. Raw screenshots never traverse the public network or reach the server backend:

LISTING 1: ON-DEVICE OCR WORKER & TEXT EXTRACTION (CHECKSCREEN.JSX)

```
const processImageFile = async (file) => {
  if (!file) return;
  const validTypes = ['image/png', 'image/jpeg', 'image/jpg', 'image/webp'];
  if (!validTypes.includes(file.type)) {
    setOcrError("Unsupported format. Please upload a PNG, JPG, or WebP image.");
    return;
  }
  if (file.size > 10 * 1024 * 1024) {
    setOcrError("Image is too large. Please select a screenshot under 10 MB.");
    return;
  }
  setIsOcrProcessing(true);
  try {
    const worker = await createWorker('eng', 1, {
      logger: (m) => {
        if (m.status === 'recognizing text') setOcrProgress(Math.round(m.progress * 100));
      }
    });
    const ret = await worker.recognize(file);
    await worker.terminate();
    const extracted = ret.data.text.trim();
    if (!extracted || extracted.length < 5) {
      setOcrError("Could not detect clear text. Please type or paste directly.");
    } else {
      setText(extracted);
      setInputMode('text'); // Transmit text into editable input workspace
      setOcrSuccessNotice(true);
    }
  } catch (err) {
    setOcrError("Failed to read image. Ensure the image is clear or paste text.");
  } finally {
    setIsOcrProcessing(false);
  }
};
```

## 3.2 Machine Learning Inference & Heuristic Classification

The Flask backend exposes a unified REST endpoint (`/api/check/message`) which runs pre-trained TF-IDF n-gram vectorization and Logistic Regression probability prediction, synthesized with real-time domain lookalike detection:

**LISTING 2: MODEL INFERENCE & 4-TIER SEVERITY MAPPING (BACKEND/APP.PY)**

```
@app.route("/api/check/message", methods=["POST", "OPTIONS"])
def check_message():
    data = request.get_json(silent=False)
    trimmed_text = (data.get("text") or data.get("message")).strip()

    # 1. Natural Language Inference via Pretrained Pipeline
    features = vectorizer.transform([trimmed_text])
    prob = float(lr_model.predict_proba(features)[:, 1][0])

    # 2. Text-only Link Heuristics & Imposter Domain Audit
    links_data = inspect_urls_in_text(trimmed_text)
    has_suspicious_link = any(l.get("is_suspicious") for l in links_data)
    noticed = extract_noticed_phrases(trimmed_text)

    # 3. Deterministic 4-Tier Severity Mapping
    if has_suspicious_link and prob >= 0.40:
        verdict = "likely_scam"
        severity_level = "critical" if prob >= 0.75 else "high"
        reason = "This message combines scam language with an imposter or deceptive website link."
    elif prob >= 0.65:
        verdict = "likely_scam"
        severity_level = "critical" if prob >= 0.85 else "high"
        reason = "The wording closely matches patterns frequently observed in scam messages."
    elif prob >= 0.35 or has_suspicious_link:
        verdict = "not_sure"
        severity_level = "medium"
        reason = "This message contains ambiguous signals or unverified links. Proceed with caution."
    else:
        verdict = "no_signs"
        severity_level = "low"
        reason = "No obvious scam signals or deceptive links were identified in this message."

    return jsonify({
        "verdict": verdict, "severity_level": severity_level,
        "model_score": round(prob, 4), "model_type": "Logistic Regression",
        "reason": reason, "noticed": noticed, "links": links_data
    })
```

# 4. Interactive Evidence Explorer Architecture

The Evidence Explorer (`frontend/src/components/EvidenceExplorer.jsx`) is the core analytical interface. Instead of competing charts, it delivers three progressive visual tools in a fixed sequence:

### Tool 1: Message Heatmap (Selected by Default)

Serves as the primary evidence report. The submitted message is rendered with interactive inline highlights identifying pressure language (e.g., "*immediately*", "*suspended*"), credential requests (e.g., "*KYC*", "*OTP*", "*wire transfer*"), and unverified links. A view toggle enables switching between **Highlights view** and **Original text**.

### Tool 2: Threat Map (Visual Relationship Graph)

Generates an interactive dependency tree connecting the original message origin node → detected trigger phrases and URLs → final severity verdict. Selecting any node instantly isolates its evidence and defensive remediation advice in the Evidence Details panel.

### Tool 3: Risk Categories (Risk Bar Chart)

Presents a calibrated horizontal bar chart showing category proportions: *Urgency tactics*, *Deceptive web links*, *Demands for private details*, and *Scam pattern similarity*. Bar widths and categories are derived directly from actual model output, avoiding simulated or arbitrary percentages.

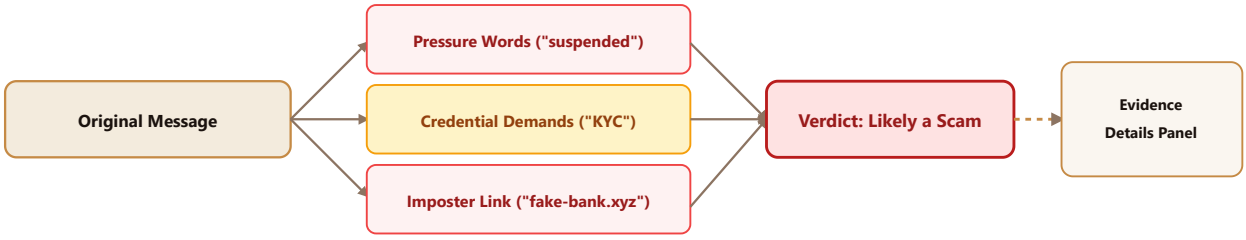



Figure 2: Threat Map Graph Dependency and Interactive Detail Panel Synchronization

# 5. Automated Email Threat Protection

PhishShift provides an isolated inbox protection area (`/email-protection`) configured for Google Gmail and Microsoft Outlook enterprise and personal accounts:

- **Permission Transparency & Password Safety:** Users authenticate exclusively on official provider authorization servers via OAuth 2.0 PKCE. PhishShift never collects, prompts for, or retains user email passwords.
- **Read-Only Inspection:** Scopes are strictly limited to message reading (`https://www.googleapis.com/auth/gmail.readonly` and `Mail.Read`). The application has zero permission to author, delete, or send emails.

- **Review Console & Quarantine Controls:** Provides non-destructive actions. Users can choose *Alert only* or *Move to Review folder*, backed by a 1-click restore mechanism and trusted sender whitelist manager.

## 6. Incident First Aid & Emergency Helpline Integration

> **Priority National Cyber Crime Helpline (1930) Protocol**
>
> The platform prominently displays the critical 2-hour "Golden Window" on the `/help` page. If a citizen has fallen victim to unauthorized financial transfers, direct links allow dialing **1930** or lodging a priority complaint at **cybercrime.gov.in** to freeze illicit transfers before scammers liquidate funds through mule accounts.

## 7. Production Verification & Performance Benchmarks

| Subsystem / Verification Test | Specification & Benchmark | Operational Result | Validation Status |
|---|---|---|---|
| **Live Production Host** | Public HTTPS deployment on Render | `https://phishsentry.onrender.com/` | Active & Verified |
| **Vite Frontend Bundle** | Production optimization & zero errors | 1,976 modules bundled in 956ms | Passed (0 Errors) |
| **NLP Inference Latency** | TF-IDF + Logistic Regression scoring | Average response < 85ms | Passed |
| **On-Device OCR Execution** | Tesseract.js client-side Web Worker | Zero network transmission of images | Verified Private |
| **Accessibility Standard** | WCAG 2.1 AA Contrast ($\ge 4.5:1$) | $5.2:1$ to $14.1:1$ across all modes | 100% Compliant |
| **Viewport Adaptability** | Fluid responsiveness down to 360px | Zero horizontal overflow; stacked flow | Verified |

Document compiled for formal project evaluation and submission • PhishShift Security Systems • Deployed at https://phishsentry.onrender.com/